

GUÍA DE ESTUDIO N° 4 → Seguridad

1) ¿Cuáles son los objetivos que se pretenden lograr con los distintos tipos de mecanismos de seguridad de la información?

- **Confidencialidad:** La información debe ser accedida por partes autorizadas, y para esto recurrimos al cifrado.
- **Integridad:** La información debe ser modificada únicamente por partes autorizadas, y para controlar esto usamos los hash.
- **Disponibilidad:** La información debe estar disponible para partes autorizadas.
- **Autenticación:** Se debe verificar la identidad de cada usuario.
- **Protección a la réplica:** Una transacción sólo pueda ser realizada una vez, a menos que se especifique lo contrario. No se deberá poder grabar una transacción para luego reproducirla.
- **No repudio:** Evita que cualquier entidad que envió o recibió información alegue, ante terceros, que no realizó dicho envío o recepción.

2) ¿Por qué es necesaria la seguridad de la información?

La información en las empresas se ha convertido en un componente esencial para mantener y asegurar la ventaja competitiva, el flujo de fondos, la rentabilidad y la imagen de la empresa. Mantener su seguridad es crucial para evitar ataques y pérdidas.

3) ¿Qué relación existe entre la criptografía y la seguridad de la información?

La criptografía es un conjunto de técnicas que buscan proteger u ocultar información frente a observadores no autorizados. La seguridad de la información busca mantener la información protegida frente a posibles atacantes. Por eso, para mantener la seguridad se pueden usar técnicas criptográficas.

4) Explique los componentes de un sistema criptográfico

Un sistema criptográfico está compuesto por un conjunto de **textos claros** (la información original), **textos cifrados** (el texto claro luego de la aplicación de algoritmos de cifrado) y **algoritmos** (que logran la transformación, en combinación con un parámetro denominado **clave**, del texto claro a texto cifrado).

5) Diferencie entre los distintos mecanismos de encriptación

Los diferentes tipos de algoritmos de cifrado suelen dividirse en tres grandes grupos:

Según la naturaleza del algoritmo

- **Sustitución:** Se cambian unos símbolos por otros.
- **Transposición:** Cambia el orden de los símbolos.
- **Producto:** Se aplican los métodos anteriores, dos o más veces.

Según la clave

- **Simétricos:** Se utiliza la misma clave para cifrar y descifrar.
- **Asimétricos:** Se utilizan claves distintas para cifrar y descifrar.
- **Irreversibles:** Cifra un texto claro no permitiendo su descifrado.

Según el número de símbolos cifrados a la vez

- **Bloque:** Dividen el texto en bloques de igual longitud, para luego cifrar cada bloque en forma independiente, normalmente de 64 bits.
- **Flujo:** El texto claro es cifrado símbolo por símbolo (bit a bit).

6) Realice un cuadro comparativo entre los distintos tipos de algoritmos de encriptación

Características	Algoritmos de Encriptación Simétrica	Algoritmos de Encriptación Asimétrica
Claves	Utiliza la misma clave en ambos extremos de la comunicación.	Utiliza dos claves diferentes: una clave privada y una clave pública.
Ventajas	- Rápidos y eficientes en términos de velocidad. - Adecuados para encriptar grandes volúmenes de datos. - Fuertes y difíciles de romper.	- No es necesario distribuir la clave pública, ya que es compartida abiertamente. - Proporciona una autenticación segura y garantiza la confidencialidad. - Adecuados para firmas digitales y sistemas de clave pública.

Desventajas	- Necesita una distribución segura de la clave simétrica. - Si la clave se pierde o se compromete, toda la comunicación encriptada se vuelve vulnerable.	- Más lentos en comparación con los algoritmos simétricos. - Consumen más recursos. - Deben utilizar claves de mayor tamaño para ofrecer seguridad comparable a los simétricos. - La pérdida de la clave privada puede ser catastrófica en términos de seguridad.
Técnicas de Encriptación	- Cifrado por Bloques: Divide los datos en bloques de un tamaño fijo y los cifra individualmente. Ejemplos incluyen AES (Advanced Encryption Standard) y DES (Data Encryption Standard).	- Cifrado de Clave Pública: Utiliza dos claves matemáticamente relacionadas, una para cifrar y la otra para descifrar. Ejemplos incluyen RSA, Diffie Hellman. - Firmas Digitales: Utiliza la clave privada para firmar mensajes y la clave pública para verificar la autenticidad de la firma. Ejemplos incluyen DSA (Digital Signature Algorithm) y ECDSA (Elliptic Curve Digital Signature Algorithm).

7) Explique qué es una función de HASH y para qué se utiliza

Es una operación que se realiza sobre un conjunto de datos de cualquier tamaño y da como resultado otro conjunto de datos “resumen” de tamaño fijo e independiente del texto original.

Para que una función de Hash pueda ser utilizada con fines criptográficos, debe poseer estas **características**: La entrada debe poder ser de cualquier tamaño. El valor hash (salida) debe tener un tamaño fijo. Debe ser fácil y rápido de calcular, encontrarse libre de colisiones (no deberíamos poder obtener dos salidas de hash iguales para entradas diferentes), y debe ser irreversible (de un solo sentido).

Las **aplicaciones principales** de las funciones Hash son: Contraseñas, Firmas Digitales, Integridad y Autenticación.

Si un origen quiere enviar un mensaje M a un destino, el origen puede enviar M y el hash de M. Así, en destino, se puede rehacer el hash sobre M y verificar si este hash es igual al

recibido por el origen. Si es así, se garantiza la integridad del mensaje, es decir, que no hubo modificaciones en el medio.

HMAC - Hash based Message Authentication Code - Código de Autenticación de Mensaje basado en Hash

A la hora de asegurar la integridad de la información transmitida o almacenada, surgió el concepto de **MAC - Código de Autenticación de Mensajes**.

Su funcionamiento radica en la inclusión de información adicional (clave compartida conocida por ambos extremos de la comunicación) como parte integral del mensaje a transmitir.

El concepto detrás de **HMAC** es el mismo pero utilizando funciones de Hash como parte integral del proceso de generación de este “Código de Autenticación”, lo que lo transforma en una herramienta aún más efectiva.

Cuando HMAC se pone en funcionamiento, el mensaje original es procesado junto a la clave de secreto compartido, por una función Hash (MD5 o SHA-1).

Esta operación produce como resultado, un valor de hash, el cual es transmitido junto al mensaje original al otro extremo de la comunicación.

El receptor, recibe el mensaje y el valor de hash enviado por el emisor, y procede a recalcular un nuevo hash, ya que conoce la clave que se combinó con la información transmitida.

Posteriormente el valor de hash enviado, es comparado con el valor de hash generado por el receptor. En caso de que ambos valores sean coincidentes, la integridad y autenticidad del mensaje estarán garantizadas.

8) ¿Qué es y para qué sirven las Firmas Digitales?

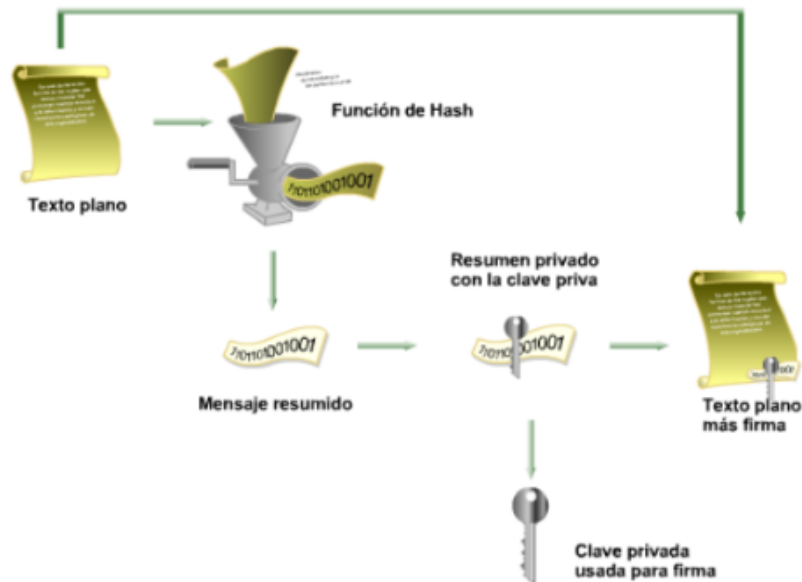
Es una herramienta tecnológica que permite garantizar la autenticidad e integridad de los documentos digitales. Es un conjunto de datos asociados a un mensaje digital, y se basa en el uso de algoritmos asimétricos y funciones de hash.

Características: única, no falsificable, fácil de autenticar, irrevocable, barata y fácil de generar.

9) Describa el mecanismo de funcionamiento de una firma digital

Se basa en el uso de **claves públicas y hash**. Iniciamos con un mensaje de texto claro a enviar. A este mensaje lo pasamos por una función de hash, y luego lo ciframos con su clave privada. Así, obtenemos el texto plano cifrado y el hash del mensaje sin cifrar. En destino, el receptor podrá descifrar el mensaje con la clave pública del emisor, y luego aplicará la misma función de hash sobre el mensaje descifrado para comparar los resúmenes (el recibido por el emisor y el recién calculado). Así, si los hash son iguales

comprobamos la integridad. La autenticidad se comprueba en el momento de descifrar el mensaje: si el emisor cifró con su clave privada, la única forma de descifrarlo es con su clave pública. Si el receptor logra descifrar el mensaje, se sabe que quien lo envió es el emisor conocido, ya que sólo él conoce su clave privada.



10) ¿A qué se llama PKI? ¿Dónde se utiliza? Describa su funcionamiento y su estructura

Las firmas digitales sólo garantizan integridad y autenticación. El cifrado con claves simétricas o asimétricas proveen confidencialidad. Sin embargo, ¿qué pasa si quiero tener todas esas características de seguridad, y no repudio? En este caso, **usamos PKI - Public Key Infrastructure - Infraestructura de Clave Pública**. Es el término utilizado para definir la combinación de software, tecnologías de encriptación y servicios, necesaria para dotar a un sistema con las características de:

- Integridad
- Confidencialidad
- Autenticación
- No repudio

PKI es considerado más bien un **Framework** y no una tecnología en sí misma. Siempre existirán al menos, una serie de componentes básicos necesarios, a la hora de hacer funcionar cualquier "Infraestructura de Clave Pública":

- **Certificados digitales:** Es el documento digital otorgado por un tercero de confianza que vincula una clave pública con una entidad.
- **Autoridad de certificación (CA):** Es el tercero de confianza (los participantes confían en él al momento de confirmar la autenticidad del otro extremo) responsable del mantenimiento final, emisión y revocación de los certificados.
- **Autoridad de registro (RA):** Se encarga del alta y baja de emisión y revocación de certificados, autenticando usuarios, solicitando y entregando los certificados. Puede

haber una Autoridad Local de registro en aquellos sitios donde la dispersión geográfica es muy grande.

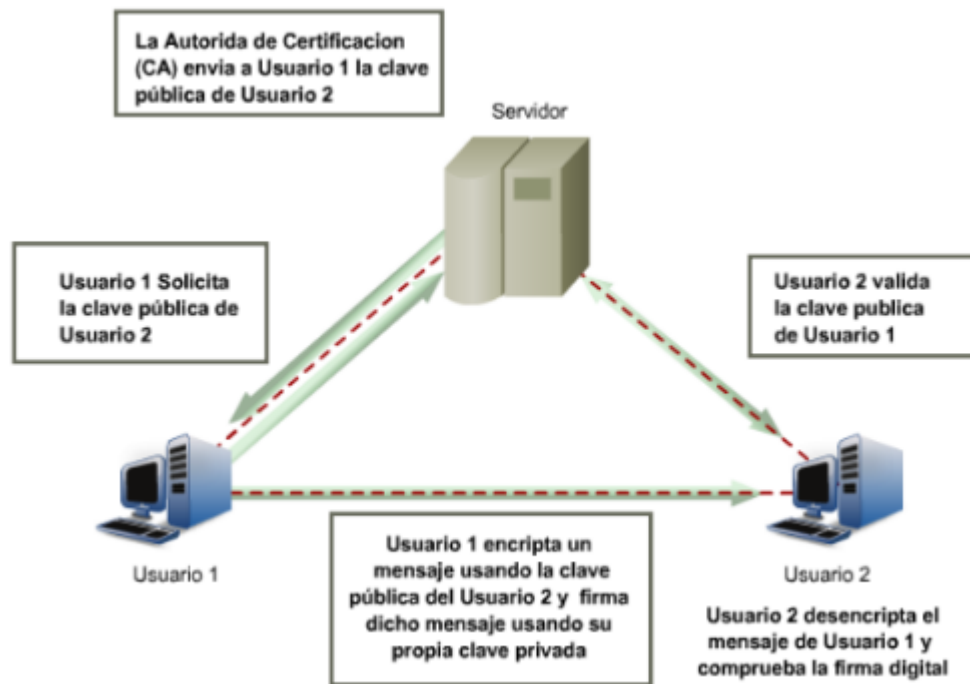
→ **Autoridad de validación (VA):** Proporciona información sobre el estado de los certificados otorgados por otras autoridades en forma On-Line.

→ **Sistema de distribución de certificados**

→ **Aplicaciones habilitadas por PKI**

Funcionamiento: Sobre Digital

1. Un usuario **A** quiere enviar un mensaje **M** a otro usuario, **B** por ejemplo
2. El usuario **A** procede a firmar digitalmente dicho mensaje **M**. Este proceso comprende el cálculo del resumen, producido por una función Hash del mensaje **M**, y la encriptación de este resumen utilizando la clave privada del usuario **A**. Para la realización de este proceso se emplea un algoritmo de firma digital como **DSA**.
3. Como se estudió anteriormente, es necesario distribuir la clave secreta, utilizada por el algoritmo de encriptación simétrico, al destinatario del mensaje, en este caso el usuario **B**. Para esta tarea se utiliza un algoritmo de encriptación asimétrico, como **RSA**
4. A los fines de poder cumplir con la etapa anterior, el usuario **A** necesita conocer la clave pública del usuario **B**, esto es posible gracias a la intervención de una Autoridad de Certificación (**CA**), quien brindará un certificado digital confiable al usuario **A**, para que éste pueda encriptar asimétricamente la clave secreta empleada en la encriptación del mensaje **M**
5. Con lo realizado hasta el momento, el usuario **A** está en capacidad de preparar el "sobre digital" para su envío al destinatario, en este caso el usuario **B**. Este "sobre digital" estará compuesto por el mensaje **M**, encriptado simétricamente, la clave secreta utilizada en este proceso, encriptada asimétricamente con la clave pública del usuario **B** y la firma digital del mensaje **M**, la cual puede estar encriptada también, en forma simétrica, de la misma manera que el mensaje original.
6. Una vez que el usuario **B** recibe el "sobre digital" procede a realizar la apertura de su contenido, para lo cual descripta la clave secreta utilizando su propia clave privada.
7. Con la clave secreta en su poder, el usuario **B** descripta el mensaje **M** y la firma digital del mismo, si es que ésta también estaba encriptada
8. A continuación procede a comprobar la identidad del usuario **A**, descriptando la firma digital con la clave pública del usuario **A**, dado que la firma se encontraba encriptada con su clave privada
9. Posteriormente el usuario **B** procede a calcular el resumen de la función de Hash del mensaje **M**, ya descriptado, y a comparar dicho resumen con el que formaba parte del contenido de la firma digital del mensaje, con la finalidad de validar la integridad del mismo.



11) Compare SSL y TLS mediante un cuadro comparativo

SSL - Secure Sockets Layer (Capa de Conexión Segura) y TLS - Transport Layer Security (Seguridad de la Capa de Transporte) son protocolos de seguridad que se utilizan para proteger la comunicación en línea y garantizar la confidencialidad e integridad de los datos transmitidos a través de Internet.

Características	SSL (Secure Sockets Layer)	TLS (Transport Layer Security)
Propósito	Encriptar datos y autenticar una conexión en Internet.	
Seguridad	Tiene fallas conocidas y se considera inseguro en su forma más antigua (SSLv2 y SSLv3).	TLS ha continuado evolucionando y mejorando la seguridad a lo largo del tiempo, eliminando las vulnerabilidades conocidas.

Uso Actual	No se usa activamente en su forma más antigua (SSLv2 y SSLv3) debido a las vulnerabilidades.	Es el protocolo de seguridad utilizado en la actualidad para proteger las comunicaciones en línea.
-------------------	--	--

SSL tiene como objetivo crear un canal de comunicaciones seguro entre una parte cliente y una parte servidor, siendo independiente del sistema operativo utilizado.

Opera en las capas de sesión y presentación (OSI). Capas transporte y aplicación (TCP).

Componentes: Change Cipher Spec Protocol, SSL Alert Protocol, SSL Handshake Protocol, SSL Record Protocol.

Es utilizado para establecer una conexión segura entre dos equipos basados en TCP.

Al momento de iniciar una conexión, **SSL** hace uso de un método denominado **Handshake**, por medio del cual se negocian aquellos parámetros básicos que regirán el resto de la comunicación.

Esquemáticamente, cuando un cliente requiere conectar con un **Servidor** utilizando **SSL**, el servidor responde a éste, indicando que una conexión segura es necesaria.

El cliente envía al servidor las “**capacidades**” de conexión del mismo.

Recibido este mensaje, el servidor evalúa la información proporcionada, respondiendo con una clave de sesión.

Si el mencionado proceso concluye correctamente, la sesión segura es establecida y permanece abierta hasta que uno de los dos extremos envíe un comando de cierre de sesión.

! Consideraciones sobre seguridad

Una de sus falencias radica en el hecho de que protege únicamente la información de una transacción comercial de origen a destino, pero no tiene injerencia sobre los datos de la misma una vez almacenados en el servidor de destino.

Por otra parte, **SSL** no provee métodos concebidos a fin de identificar transacciones y evitar el “**repudio**” de las mismas.

TLS fue construido sobre la base de **SSL 3.0** y contando tan solo con algunas pocas diferencias respecto a éste:

- **TLS** no soporta el algoritmo de cifrado simétrico **FORTEZZA** que sí es soportado por **SSL 3.0**. Esto es debido a que **TLS** busca ser íntegramente público mientras que **FORTEZZA** es un algoritmo propietario.

- **TLS** introduce un nuevo mecanismo en el relleno de los bloques para frustrar ataques basados en el análisis de la longitud de los mensajes.
- **TLS** utiliza un mecanismo diferente y más seguro en el cálculo del **MAC**.
- **TLS** introduce nuevos códigos de alerta no contemplados por **SSL 3.0**.

Componentes: Application Protocol, TLS Handshake Protocol, TLS Alert Protocol.

12) ¿Qué es un Firewall? Clasifique los distintos tipos de Firewalls que conozca

Un firewall es un sistema que hace cumplir políticas de control de acceso entre redes.

Consiste en un dispositivo formado por uno o varios equipos que se sitúan entre la red de la empresa y la red exterior (normalmente la Internet) y que analiza todos los paquetes que transitan entre ambas redes, filtrando los que no deben ser reenviado de acuerdo con un criterio establecido de antemano, de forma simple.

Son resistentes a los ataques, son el único punto de tránsito entre redes y hacen cumplir las políticas de seguridad.

Para que no se convierta en cuello de botella en la red, deben de procesar los paquetes a una velocidad igual o superior al router.

Crea un perímetro de seguridad y defensa de la organización que protege.

Su diseño ha de ser acorde con los servicios que se necesitan tanto privados como públicos (WWW, FTP, Telnet) así como conexiones remotas.

Al definir un perímetro, el cortafuegos opera también como NAT (Network Address Translation) y Proxy (servidor multi pasarela).

✓ Evita la exposición de equipos sensibles y de aplicaciones críticas, al acceso de usuarios que no son de confianza.

✓ Previenen la explotación de fallas en los protocolos mediante la desinfección del flujo de protocolos.

✓ Previenen los datos maliciosos que pueden ser enviados hacia servidores y/o clientes.

✓ Brindan políticas de seguridad robustas, simples y escalables.

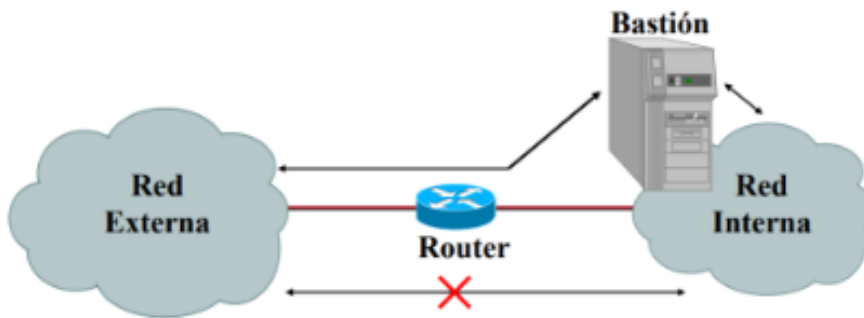
✓ Reduce la complejidad de la gestión de seguridad, mediante la delegación de la mayor parte del control de acceso a unos pocos puntos de la red.

Existen diferentes tipos (configuraciones) de Firewall:

→ Screened host firewall - Firewall de host filtrado

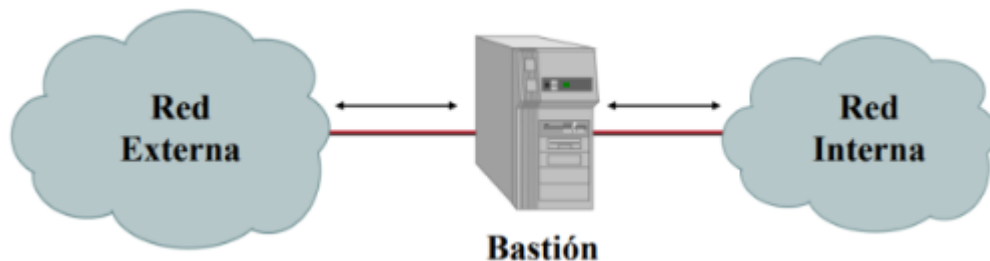
Tenemos un router separando la intranet de la Internet que puede enviar el tráfico de entrada sólo al host bastión. Bloquea todo el tráfico hacia la red interna excepto a este host, por el que pasará todo el tráfico entrante.

Se sugiere que el **bastión esté antes del router**, ya que si lo atacan tendrán acceso directo a la red interna.



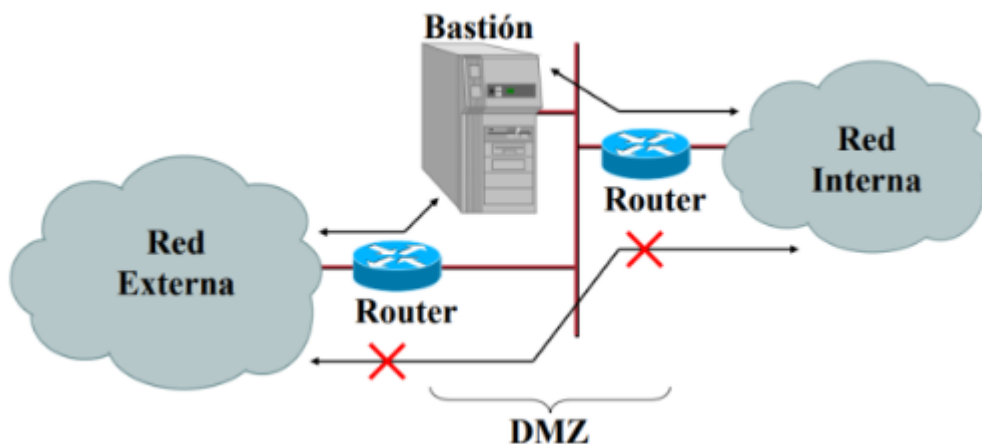
→ Dual homed gateway - Gateway de doble conexión

Tenemos un host bastión para las aplicaciones permitidas, que filtra hasta la capa de aplicación, separando la red interna de la externa. Este host tiene dos placas de red conectadas a redes diferentes.



→ Screened subnet - Subred filtrada

En este caso tenemos dos routers separando las redes interna y externa, y un host bastión en el medio de los dos routers, lo que hace que si un atacante entra al bastión todavía le quede pasar por un router. Esta red interna se conoce como zona desmilitarizada. El tráfico sospechoso se envía hacia el bastión, y el resto se envía a la red.



Niveles de filtrado en los cortafuegos

- **A nivel de red:** con direcciones IP y la interfaz por la que llega el paquete, generalmente a través de listas de acceso (en los routers)
 - **A nivel de transporte:** con los puertos y tipo de conexión, a través de listas de acceso (en los routers)
 - **A nivel de aplicación:** con los datos, a través de pasarelas para las aplicaciones permitidas analizando el contenido de los paquetes y los protocolos de aplicación (ejemplo servidor proxy o pasarela multiaplicación)
-

Tipos de filtros de Firewall

- **Filtrado de paquetes:** es un router con capacidad de filtrar algunos de los contenidos de los paquetes (examina la capa 3 y algunos puertos de capa 4).
 - ✓ Está basado en un simple juego de reglas permit/deny.
 - ✓ Tiene bajo impacto en la performance de la red.
 - ✓ Fácil de implementar.
 - ✓ Soportado por la mayoría de los routers.
 - ✓ Realiza el 90% de las tareas de un Firewall de alta gama, pero con un costo menor.
 - ✗ Es susceptible al IP spoofing.
 - ✗ No filtra bien los paquetes fragmentados.
 - ✗ Las listas de control de acceso complejas son difíciles de implementar y mantener.
 - ✗ No puede filtrar de forma dinámica ciertos servicios.
- **Statefull:** realiza un seguimiento del estado de la conexión: si la conexión está en una iniciación, transferencia de datos, o en estado de terminación.
 - ✓ Utilizado como medio principal de defensa al filtrar el tráfico no deseado.
 - ✓ Fortalece el filtrado de paquetes.
 - ✓ Mejora el rendimiento del filtrado de paquetes o proxy servers.
 - ✓ Protege contra ataques de IP spoofing.
 - ✓ Permite una mayor información de registro (logs) que un Firewall de Filtrado de Paquetes.
 - ✗ No se pueden prevenir los ataques de nivel de aplicación.
 - ✗ No todos los protocolos son de estado como UDP e ICMP.
 - ✗ Algunas aplicaciones abren varias conexiones que requieren toda una nueva gama de puertos abiertos para permitir que esta segunda conexión funcione.
 - ✗ No soportan autenticación.
- **Firewall de aplicación o Proxy Firewall:** filtra información de capas 3 a 7. El control del Firewall y el filtrado se realiza por software.
- **Firewall de traducción de direcciones:** expande el número de IPs disponibles y oculta el diseño de red interno.

- **Basados en host:** es una PC o un Server con un software de Firewall ejecutándose.
 - **Transparente:** filtra el tráfico IP entre un par de interfaces puenteadas (bridged).
 - **Firewall Híbrido:** posee alguna combinación de los Firewalls anteriores. Por ejemplo: un “application inspection Firewall” combina las funcionalidades del statefull y el application gateway.
-

Servidor Proxy

El **Proxy** no es más que el punto de empalme entre el ordenador con el que las personas realizan su búsqueda a través de la web y el servidor que contiene en sí a la página a visitar o todo aquel lugar dentro de la red que desea visitar.

Un **Proxy** es un elemento que ayuda o sirve para interpretar las solicitudes de los usuarios, que llevan por destino a las distintas páginas disponibles en la red; para de esta forma anexar una capa de seguridad entre ambos, que evite el filtrado de información privada de ambos (ordenador o página web) y permitiendo una eficiente respuesta a las solicitudes de información.

Utilidades

Los proxys sirven para el almacenamiento caché de los datos solicitados. Esto facilita que cuando el usuario que ya ha hecho una demanda de información a una web específica, el proxy vuelve a analizar si es idéntica, procediendo a responder con base en su memoria; si hay ligeros cambios, completa los datos con solicitudes específicas a la página destino.

Sirve también para mantener la privacidad de los usuarios, dado que el proxy funciona como puente de enlace y él es quien hace la solicitud, evitando que el servidor guarde la información de los ordenadores solicitantes.

Es una capa de seguridad, debido a que evita el tráfico indiscriminado por la web hacia páginas prohibidas o de dudosa fidelidad, con contenido de malware o virus encargados del robo de datos privados

Listas de acceso

Son una técnica de filtrado de paquetes, que consiste en una lista de órdenes ejecutadas secuencialmente a la llegada/salida de cada paquete en las interfaces del router, con las opciones de **permit** o **deny** al cumplir la condición especificada en la secuencia según la información de la cabecera del paquete IP y de transporte. Al realizarse en el propio router, suelen ser rápidas frente a otra técnica de filtrado.

> **permit** tcp 192.168.0.0 0.0.255.255 host 172.16.1.2 eq 443

> **deny** any any

Inconveniente: Al procesarse los paquetes de forma independiente, no se guarda información de contexto (no se almacenan históricos de cada paquete), ni se puede analizar

a nivel de capa de aplicación, dado que está implementado en los routers. Además, son difíciles de seguir en ejecución.

Recomendaciones: Situar los filtros lo más cerca posible del elemento a proteger. No filtrar el mismo tráfico más de una vez.

Detección de intrusos - IDS

Es complementario al Firewall y es necesario ya que en muchas ocasiones el atacante enmascara el ataque en tráfico permitido por el cortafuegos por lo que, para detectarlo se necesita un IDS.

- Debe estar continuamente en ejecución y debe poderse analizar él mismo y detectar si ha sido modificado por un atacante.
- Debe utilizar los mínimos recursos posibles.
- Debe adaptarse fácilmente a los cambios de sistemas y usuarios.

Tipos de IDS según localización

- **NIDS (Network Intrusion Detection System):** detecta los paquetes armados maliciosamente y diseñados para no ser detectados por los cortafuegos.
 - ✓ No se requiere instalar software adicional en los servidores.
 - ✗ Es local al segmento, si la información es cifrada no puede procesarla.
- **HIDS (Host Intrusion Detection System):** analiza el tráfico sobre un servidor.
 - ✓ Registra comandos utilizados, es más fiable, mayor probabilidad de acierto que NIDS.

Tipos de IDS según modelos de detección

- **Detección de mal uso:** verifica sobre tipos ilegales de tráfico, secuencias que previamente se sabe que se utilizan para realizar ataques.
- **Detección de uso anómalo:** verifica diferencias estadísticas del comportamiento normal de una red, según franjas horarios, según la utilización de puertos.

Tipos de IDS según modelos de acción

- **Pasivos:** registran una violación y generan alertas.
 - **Reactivos:** responden ante la situación, anulando la sesión o rechazando la conexión por el cortafuegos.
-

13) ¿Qué es una VPN y para qué se utiliza?

Una **VPN - Virtual Private Network - Red Privada Virtual** es una tecnología de red que permite una extensión segura de la LAN sobre una red pública. **Virtual** porque es

información de una red privada (LAN) que se transporta sobre una red pública. **Privada** porque el tráfico está encriptado.

14) Clasifique a las VPNs

→ **VPN de acceso remoto:** Se levanta entre un usuario y un dispositivo concentrador de VPN, que puede ser un router o un servidor. Se lleva adelante una autenticación de una vía, es decir, el concentrador autentica al usuario. Se pueden crear usando IPSec o SSL. Este tipo se subdivide en

- ◆ **Conexión VPN sin cliente:** La conexión se asegura usando SSL en un navegador web.

- ◆ **Conexión VPN basada en cliente:** Se usa un software de cliente VPN.

→ **VPN sitio a sitio:** Se levanta entre dos routers con un túnel encriptado. Todos los hosts envían y reciben tráfico a través de un gateway que soporta VPN. Se ejecuta una autenticación de dos vías, ya que cada router debe autenticar al otro.

15) ¿Qué es IPsec? ¿Qué elementos componen su estructura?

IPv4 no ofrece cifrado de comunicaciones. La privacidad de la información es una necesidad. A nivel de red, se ofrece **IPSec** como solución, que en sí es un protocolo, pero podemos decir que es un **framework** ya que está compuesto por un conjunto de protocolos de seguridad que brindan confidencialidad, integridad y autenticación.

IPSec busca proteger el contenido de las cabeceras IP contra ataques mediante autenticación de la cabecera y cifrado del contenido. También tiene como **objetivo** defender los equipos contra ataques de red mediante filtrado de conexiones (sniffing) y autenticación de conexiones.

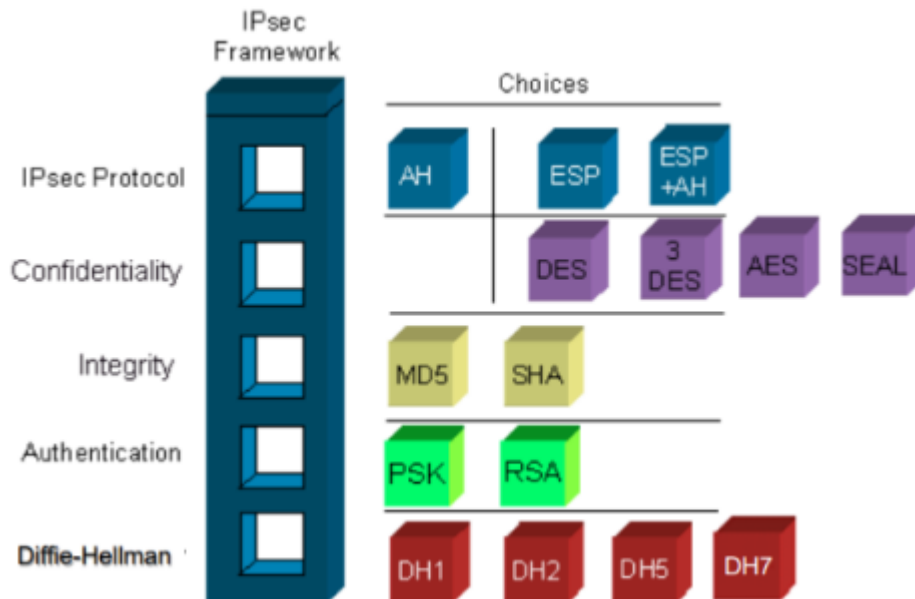
El proceso de cifrado se compone de dos protocolos, que son **AH** y **ESP**. Se pueden usar en conjunto o elegir uno de los dos. Además, usa un protocolo de gestión de claves llamado **IKE**.

AH - Authentication Header - Encabezado de Autenticación: provee autenticación e integridad. Se aplica una función de hash sobre el encabezado IP y el campo de datos. El hash crea un nuevo encabezado encriptado que se antepone al paquete original. El nuevo paquete se transmite al router IPSec par y el receptor hace un hash del encabezado IP y del campo datos del paquete recibido y compara los resúmenes.

ESP - Encapsulating Security Payload - Carga útil de Seguridad Encapsulada: provee cifrado, autenticación e integridad. Encapsula los datos originales en un nuevo paquete, aplicando cifrado y autenticación a estos datos encapsulados. El receptor, que comparte una clave con el remitente, puede descifrar el paquete y verificar su autenticidad e integridad. Esto asegura que los datos no se alteren ni intercepten durante la transmisión.

IPSec se puede usar en **dos modos de trabajo**

- **Modo de transporte**, donde el cifrado se realiza de extremo a extremo.
- **Modo de túnel**, donde el cifrado se realiza sólo entre los extremos del túnel.



16) Defina IKE. Describa su funcionamiento

IKE - Internet Key Exchange - Intercambio de Clave de Internet es un protocolo para compartir claves en un entorno IPsec con VPN.

Tiene dos modos de funcionamiento, **modo principal** y **modo rápido**. Durante el **modo principal** se lleva adelante la fase 1, donde se negocian las políticas de IKE (ambos extremos determinan qué algoritmo y técnicas se usarán para la encriptación, es decir, las políticas que protegerán el intercambio). Usando Diffie Hellman se realiza el intercambio de claves y se verifica la identidad de la otra parte; autenticamos al par con diferentes métodos. Al final de esta fase tendremos el túnel VPN creado, con una asociación segura bidireccional establecida. Por otro lado, tenemos el **modo rápido**. En este caso, durante la fase 1 se envían las políticas de IKE y la clave Diffie Hellman en el mismo momento. Se confirman las políticas, se calcula la clave secreta compartida, se verifican las identidades de los extremos y comienza la fase 2, que consiste en el intercambio y negociación de políticas IPsec. Al finalizar, se establecen las asociaciones de seguridad unidireccionalmente para cada protocolo y algoritmo.

17) ¿Cuáles serían los pasos o fases necesarios para armar una VPN con IPsec?

1. El host A envía el llamado tráfico interesante al host B.
2. Los routers de cada host negocian una sesión IKE, la fase 1, establecen los protocolos que se usarán.
3. Los routers pasan a la fase 2 y negocian ahora una sesión IKE con la asociación de seguridad IPsec.
4. Se intercambian los datos por el túnel IPsec creado.
5. Al finalizar la transmisión, el túnel se cierra.

18) ¿Cuáles son las distintas opciones de seguridad previstas en el estándar 802.11? Realice un cuadro comparativo

Opción de Seguridad	Descripción
Autenticación Abierta	- Acepta cualquier estación que intente conectarse al punto de acceso (AP). - No se requiere una clave compartida.
Autenticación por Clave Compartida	- El AP envía un mensaje en texto claro al host que intenta conectarse. - El host debe responder con el texto cifrado utilizando una clave compartida. - El AP cifra el mensaje y compara los resultados para verificar que se tiene la misma clave.
Privacidad (WEP - Wired Equivalent Privacy)	- Encripta los paquetes antes de su transmisión por el canal. - Cada paquete se encripta con una clave distinta, que se forma mediante la concatenación de un campo del paquete con la clave compartida.

Es importante destacar que, aunque **WEP** proporcionaba cierto nivel de seguridad, se considera obsoleto y se ha demostrado que es vulnerable a varios tipos de ataques. En la actualidad, se recomienda utilizar protocolos de seguridad más robustos, como **WPA (Wi-Fi Protected Access)** o **WPA2**, para proteger las redes inalámbricas 802.11. Estos protocolos ofrecen un mayor nivel de seguridad que WEP y son más difíciles de vulnerar.

19) Defina y describa el funcionamiento de 802.1x.

802.1x es un estándar que especifica los mecanismos necesarios para llevar un control de acceso por puerto en redes 802. Define el control de acceso por puerto. Cuando un dispositivo quiere acceder a una red a través de un AP, este le solicita unas credenciales a través del protocolo **EAP - Extensible Authentication Protocol - Protocolo de Autenticación Extensible**. El access point recibe las credenciales y las reenvía a un servidor de autenticación RADIUS quien autoriza su acceso en caso de que sean correctas.

Diseño de un sistema de seguridad

El proceso de diseñar un sistema de seguridad podría decirse que es el encaminado a cerrar las posibles vías de ataque, lo cual hace imprescindible un profundo conocimiento acerca de las debilidades que los atacantes aprovechan, y del modo en que lo hacen.

Existe una gran variedad de ataques posibles para distintas vulnerabilidades.

Los intrusos, antes de poder atacar una red, deben obtener la mayor información posible acerca de esta; intentan obtener la topología, el rango de IPs de la red, los S.O, los usuarios, etc.

El administrador debe saber, que existen organismos que informan de forma actualizada, las técnicas de ataque utilizadas y novedades, ej: **CERT/CC (Computer Emergency Response Team Coordination Center)** <http://www.cert.org>, <http://escert.upc.es>

Soluciones de seguridad



Herramientas de seguridad

- Protocolos seguros (IPsec, SSL, SSH).
- Almacenamiento de claves (tarjetas inteligentes).
- Certificados (X.509).

¿ A qué nivel se gestiona la seguridad?

1. **Sistema operativo:** contraseñas, permisos de archivos, criptografía.
2. **Protocolos y aplicaciones de red:** permisos de acceso, filtrado de datos, criptografía.
3. **Identificación de personal:** dispositivos de identificación personal, criptografía.

! Todo esto se debe reflejar en el BOLETÍN DE POLÍTICA DE SEGURIDAD

Gestión de Seguridad



Tendencias de seguridad

“la concentración de la seguridad en un punto, obligando a todo el tráfico entrante y saliente pase por un mismo punto, que normalmente se conoce como cortafuegos o firewall, permitiendo concentrar todos los esfuerzos en el control de tráfico a su paso por dicho punto”

Metodología de seguridad

La primera tarea a realizar en una red es redactar la política de seguridad. Tras ello, conocer la estructura (topología, accesos) de la red y finalmente, auditar la red para ver su estado en búsqueda de detección de vulnerabilidades.

Este proceso de detección de vulnerabilidades consiste en:

- Examen de hosts y elementos de la red, por vulnerabilidades conocidas.
 - Puertos abiertos (observar servicios conocidos según /etc/services).
 - Chequeo de la estructura de ficheros e integridad del sistema en el caso de servidores (por ejemplo con herramientas como tripwire).
-

PUERTOS

	TCP		UDP	
	Común	Seguro	Común	Seguro
DHCP	-	-	67, 68	-
DNS	-	-	53	853
WinS	42	-	42	-
SMB	139,445	-	-	-
NetBEUI	139	-	-	-
FTP	20, 21	21, aleatorio*	-	-
SFTP	-	22	-	-
TFTP	-	-	69	-
SNMP	-	-	161,162	-
SMTP	25	465	-	-
IMAP	143	993	-	-
POP	110	995	-	110 
HTTP	80	443	-	-